Week 1_Organization_Profile_and_Scope

1-The firm

Why: This section presents the organization being audited. The organization is fictional: auditing a real organization would need its written permission, and would involve real people's data.

• **Name:** Alder & Co Accounting (fictional)

• **Activity**: accounting, tax returns and payroll for small local businesses.

• **Location:** Luxembourg, one office.

• **Staff:** 10 employees.

2- Staff and roles

Why: Each role handles different data, which shows who needs access to what. It also shows that nobody works on IT full-time.

Role	Number	What it means for the audit
Owner / Director	1	Runs the firm & decides which risks to fix & accept.
Senior accountant	2	Works on client tax & financial records.
Accountant	5	Works on client tax & financial records.
Payroll officer	1	Handles salaries: access to the most sensitive data.
Office administrator	1	Runs the office & also handles basic IT.
Total	10	

The roles are fictional and reflect a typical small accounting office, so that each type of data has a clearer user.

3-IT environment

Why: Describes the machines the firm uses, so it is clear what can be audited and what cannot.

• **10 Windows 11 laptops**, one per employee, all with the same standard setup. Windows is a common choice for office laptops, and the shared setup is what allows one laptop to represent all ten.

• **1 Ubuntu server** representing the firm's file server, where staff store shared folders, client files and payroll files.

• **Email and accounting software**: run by external providers on their own systems. The firm uses them but doesn't own them, so they can't be audited here. The firm remains responsible for the data these services hold.

• **No dedicated IT staff:** the office administrator manages IT part-time, which is realistic for a small firm of ten and explains why gaps may exist.

• **No written security policy**: this is why an Acceptable Use Policy is part of the deliverables (week 3).

4- Main data

Why: The more sensitive the data, the more the machine holding it needs protection. This drives the asset inventory and the priority of each gap.

Date	Level	Reason
Payroll data & staff personal details	Restricted	Salaries & personal info; seen only by the payroll officer & the owner
Client tax & financial records	Confidential	Client's info, used daily by the 7 accountants; a leak would harm clients & the firm's reputation.
Internal procedures & templates	Internal	For staff only; a leak would cause little harm.
Website content & brochures	Public	Meant to be seen by anyone.

Client records and payroll are both sensitive. Restricted is kept for the data seen by the fewest people. Payroll is limited to two people (payroll officer and owner), while client records are used by all seven accountants.

5- Audit scope

Why: States clearly what is checked, what is not, against which reference, how and when.

In scope

Machine	Role	Audit tool & version
Window 11 virtual machine	Represents the 10-employee laptop	HardeningKitty 0.9.4, CIS Windows 11(24H2) list.
Ubuntu 24.04.5 server	Represents the file server	Lynis 3.0.9
Kali Linux	My audit workstation, also audited as agreed.	Lynis 3.1.6

Each system installs its own Lynis version; the version used is recorded for each machine.

- **Out of scope**: email and accounting software (external providers); router, Wi-Fi and printer,
- **Reference frameworks**: NIST CSF 2.0 and CIS Controls v8.
- **Method:** read-only audit tools. No settings are changed on any machine.
- **Period**: 2 to 27 November 2026.

6-Assumptions

- The firm and its staff are fictional.
- All laptops share one standard setup, so one sample represents them.
- The Ubuntu server represents the firm's file server.